EWB COURSES

AI-POWERED CYBERSECURITY

Assessment 01: Security Foundations

Name: Rana Pratap Tejavath

Batch/Group: 01

Course: EWB COURSES – AI-POWERED CYBERSECURITY

Date: 30 OCT 2026

Task A – Secure a Student Account (25 marks)

Scenario (from the assessment): Mira uses the same short password for her email and learning portal. She approves unexpected sign-in prompts, postpones device updates and keeps her only project copy on one laptop. A friend sometimes uses that laptop under Mira's signed-in account.

A1 and A2 – Risks, controls and limitations

Risk	Asset	CIA impact	Control (and why it helps)	Limitation
1. Same short password reused for email and learning portal. One leak or guess opens both, and email can reset other accounts.	Email account and learning portal account	**C:** messages and coursework can be read. **I:** an intruder can send or edit things as Mira.	Use a different long passphrase for each account, kept in a password manager. One leak no longer opens both accounts, and length makes guessing harder.	The manager's master password becomes a single point of failure, and Mira must keep the habit for every new account.

Risk	Asset	CIA impact	Control (and why it helps)	Limitation
2. Approving unexpected sign-in prompts. An approval tells the system Mira is signing in, even if she is not.	Her multi-factor authentication (MFA) approvals and active sessions	**C:** a stranger can see private data. **I:** they can change settings or content.	Deny any prompt she did not start and report it; prefer MFA that needs a number match or code. A stranger cannot finish sign-in without that extra detail.	It still depends on Mira paying attention when prompts repeat. Not every service offers number matching.
3. Postponed device updates leave known weaknesses open.	Mira's laptop and the data and sessions on it	**C:** malware could steal data. **I:** files or settings could be altered. **A:** the laptop could be damaged or locked.	Turn on automatic updates and install pending ones. Known flaws are closed without relying on memory.	Updates need restarts and can cause compatibility problems. They cannot stop flaws that are not yet known.
4. Only copy of the project is on one laptop. Loss, damage, infection or deletion means the work is gone.	Mira's project files	**A:** work becomes unavailable or lost. **I:** a damaged file may have no clean version to restore.	Keep two copies: one in trusted cloud or college storage and one on a separate drive. One failure no longer destroys the project.	Backups need their own protection, sync tools can copy mistakes or deletions, and an untested backup may fail when needed.

Risk	Asset	CIA impact	Control (and why it helps)	Limitation
5. Friend uses the laptop under Mira's signed-in account. Anything the friend does looks like it came from Mira.	Mira's signed-in session, files, email and portal	**C:** the friend can view private content. **I:** they can edit, delete or send things as Mira.	Lock the screen when away, sign out when done, and give the friend a separate guest account. The friend sees only their own space.	It relies on habits and trust. A shared password or an unlocked laptop still gives access, and short lock timeouts can feel inconvenient.

(C = confidentiality, I = integrity, A = availability.)

Priorities – the first three actions

1. **Create unique passphrases, starting with email.** Password reuse is the root weakness: one leak opens two accounts, and email can reset others. It reduces the most damage for the least effort.
2. **Stop approving unexpected prompts.** If the password is already weak or exposed, the MFA prompt is the last barrier. This habit change is free and immediate, and it stops someone with the password from finishing sign-in.
3. **Stop shared signed-in use (lock screen and guest account).** Misusing it needs no technical skill: the friend just sits down at the laptop. It is quick to fix and removes direct access to everything.

Backups and updates come next. Backups matter greatly because lost work cannot be recovered, but they do not stop an account takeover today. Updates follow because exploiting old flaws usually needs a more skilled attacker.

A3 – Authentication versus authorisation (Mira's learning portal)

Authentication is proving who the user is. When Mira signs in to the learning portal with her password and approves the MFA step, the portal is checking that the person really is Mira.

Authorisation is deciding what the authenticated user is allowed to do. Once Mira is signed in, the portal allows her to view her own courses, submit her own assignments and see her own grades, but not edit marks or see other students' records.

Authentication comes first ("who are you?"), then authorisation ("what may you do?"). Mira's weak password and unexpected approvals weaken authentication. When her friend uses her signed-in session, the portal authenticated Mira only once, so it authorises the friend as if they were Mira.

Task B – Analyse a Suspicious Message (25 marks)

This analysis uses only the supplied fictional text. I did not visit or test any sample address, and I am not proving that a real sender or website is malicious. The college normally uses **campus.example**.

B1 – Five warning signs

#	Phrase from the message	Why it needs scrutiny
1	“FINAL WARNING - scholarship expires in 20 minutes”	Extreme urgency leaves no time to check. Pressure to act fast is a common phishing tactic.
2	“enter your college password and OTP”	A password plus a one-time code is exactly what is needed to take over an account. A genuine college should not ask for both through a link in a message.
3	“campus-awards.example”	The sender and link domain differs from the college’s normal **campus.example**. It looks similar but is not the same, so it needs independent checking.
4	“help@personal-awards.example”	The Reply-To address differs from the From address and uses yet another domain, so replies would go somewhere other than where the message appears to come from.
5	“Do not contact the college office”	Telling the reader not to check with the official source blocks the normal way to verify the message.

The request to “Reply with a photo of your identity card” also asks for sensitive personal data through an unverified channel.

B2 – Safe verification process

1. Do not click the link, reply, or send any document or code.
2. Get the college’s official contact **independently**: type the known college portal address yourself or use a saved bookmark, or use the scholarship office details from an official notice or the college’s own website. Do not use anything from the message.
3. Contact the scholarship office through that contact and ask whether a scholarship has been approved for you and whether any action is needed.
4. Compare the message’s domains with **campus.example** and note the differences.
5. Report the message to the college IT or security team through an official route.

Why HTTPS alone does not prove the message is genuine: HTTPS only means the connection to a website is encrypted. It does not show who owns the site or whether the message is honest, and anyone can set up a fake site that uses HTTPS.

Why a familiar display name alone does not prove it is genuine: The display name ("Scholarship Desk") is just text the sender chooses. The actual address and domain behind it can differ, and here they do not match the college's normal domain.

B3 – Response plan for a student who already entered a password and OTP

No one should ask the student to share the password or OTP. None is needed for any step below.

1. **Immediate containment.** From a trusted device, change the college password by going to the official portal directly, not through the message link. Sign out of all other sessions and devices if the portal allows it, and stop replying to the message.
2. **Immediate containment.** Remove any unfamiliar devices or MFA methods and confirm the recovery email and phone number are still the student's own.
3. **Official reporting.** Tell the college IT/security team promptly through the official channel, giving the message details and when the information was entered. If an identity card photo was sent, report that too.
4. **Follow-up checks.** Review recent sign-in activity and account settings (for example, forwarding rules). Change the password on any other account that used the same or a similar password.
5. **Follow-up checks.** Watch for further suspicious messages or misuse of identity card details. Give the original message to IT only, and do not post screenshots or identity documents in a group chat.

B4 – One fact that cannot be established from the message alone

Fact: Whether the scholarship award is real, that is, whether the college actually sent this message or controls these domains.

Evidence that would help: Confirmation from the college scholarship office through an independently obtained contact, the message's full technical headers (which IT can review) and a record of which domains the college officially uses.

Task C – Triage a Sign-in Alert (25 marks)

All times are IST on 18 October 2026. The lab notes say **192.0.2.10** is the usual classroom egress, and that a different IP alone is not proof of an attacker. The user is student07. Reasoning below uses only the supplied log and statement.

C1 – Four-point timeline

#	Time	Observed event / evidence	Interpretation (not proven)
1	09:00–09:01	Password authentication succeeded and MFA was approved from 192.0.2.10.	Consistent with a normal classroom sign-in, since this is the usual egress. The log shows no session creation at this time.
2	10:14–10:16	From 198.51.100.23: password failed (10:14), failed (10:15), then succeeded (10:16).	An unfamiliar source with two failures then a success could suggest guessing or reuse of a known password, but a typing mistake is also possible. The log cannot tell which.
3	10:17–10:18	MFA denied (10:17), then approved (10:18). student07 says they did not sign in after 09:05 and approved a prompt around 10:18 to stop repeated requests.	Matches approving prompts out of annoyance (prompt fatigue). The log does not show who denied at 10:17.
4	10:20	A session was created from 198.51.100.23.	Access was granted from that source after the approval. The logs do not show what was done during the session.

C2 – Explanations and checks

Likely explanation: Someone other than student07 entered the correct password after two failures from 198.51.100.23, triggering MFA prompts. The student, who says they did not start the sign-in, approved one to stop the prompts, and that approval let the session be created. This fits the statement, the repeated prompts and the unusual source.

Alternative explanation: The sign-in was legitimate. For example, student07 or someone they trust signed in from a different network than usual and mistyped the password twice, and the student's statement is mistaken or incomplete.

Two additional checks to distinguish them:

1. **Device and session details.** Check whether the device or browser used for the 10:16–10:20 session has been used and registered by student07 before.
2. **MFA and student context.** Check which device approved the 10:18 prompt and how many prompts were sent, and ask student07 where they were and on which network at 10:14–10:20.

Neither explanation is proven, and the source IP does not identify a person.

C3 – Three prioritised response actions for the authorised IT team

1. **Protect the account (first, urgent).** Revoke the session created at 10:20, reset the password through a secure process (never asking the student to send it), and review and remove unknown MFA methods. This stops any continuing access.
2. **Preserve evidence (start immediately, alongside action 1).** Export and securely store student07's authentication, MFA and session logs from about 09:00 to 10:20 before changes make them harder to interpret. Record times and who handled them, and do not delete anything.
3. **Investigate and monitor.** Review what the session did (such as mailbox rules or file access), carry out the two checks in C2, tell the student what happened and why to deny unexpected prompts, and watch for repeat attempts.

C4 – Incident summary (79 words)

Logs show student07's password succeeded at 10:16 from 198.51.100.23 after two failures, followed by an MFA denial, an approval at 10:18 and a session at 10:20. The student says they did not sign in and approved a prompt to stop repeated requests. This suggests possible unauthorised access, but the source IP does not identify a person and no post-login activity is shown. Priority: high. Next action: IT should revoke the session, reset credentials, preserve logs and review account activity.

Task D – Review an AI Security Answer (25 marks)

Fictional AI output (as supplied): "The email is safe because it uses HTTPS. The sign-in logs prove that the person using 198.51.100.23 stole the password. MFA prevents every account compromise. Delete the suspicious logs and send the student's password to support so they can test it."

D1 – Five unsafe or unsupported claims, corrected

#	Unsafe/unsupported claim	Why it is incorrect or unsafe	Corrected position
1	"The email is safe because it uses HTTPS."	HTTPS only encrypts a connection. It does not show who sent the message. In Task B the sender/link domain differs from campus.example, the Reply-To differs, and the message demands a password and OTP.	Treat the message as suspicious and verify it through an official contact (CISA Secure Our World phishing guidance).
2	"The sign-in logs prove that the person using 198.51.100.23 stole the password."	The logs show events from an IP address, not who was behind it or how the password was obtained. The assessment itself says a different IP alone is not proof of an attacker.	The logs suggest possible unauthorised access, which needs more evidence such as device details and MFA approval records.
3	"MFA prevents every account compromise."	No control is perfect. In Task C an MFA approval at 10:18 was followed by a session at 10:20, and the student says they approved a prompt to stop repeated requests.	MFA greatly reduces risk but can be defeated if a user approves an unexpected prompt (CISA guidance on MFA).
4	"Delete the suspicious logs."	Logs are the evidence needed to understand what happened. Deleting them could destroy proof.	Preserve and protect the logs for the authorised IT team.

#	Unsafe/unsupported claim	Why it is incorrect or unsafe	Corrected position
5	“Send the student’s password to support so they can test it.”	Passwords must never be shared, and support does not need them. Sending one creates a new risk and breaks the assessment’s rule on passwords and OTPs.	The student changes the password through the official process. Support can help without seeing it.

The AI output is also an example of confident but unsupported statements, which NIST AI 600-1 calls confabulation and says should be checked against evidence.

D2 – A better prompt for an AI tool

> “You are helping with a training exercise. Analyse ONLY the fictional evidence I paste below (a made-up phishing message and a small synthetic sign-in log). Do not use outside assumptions about real people or systems. Do not ask me for any password, OTP or personal data, and do not suggest sending them to anyone.
>
> 1. List what is directly observed in the evidence (facts only).
> 2. List your interpretations or assumptions separately and label them as such.
> 3. State how confident you are in each interpretation and what additional evidence would raise or lower that confidence.
> 4. Suggest safe next steps, including preserving evidence and verifying through an official contact.
> 5. Do not claim an IP address identifies a specific person. If the evidence is not enough to conclude something, say so clearly.”

D3 – My corrected security advice (118 words)

Do not treat the email as safe just because the link uses HTTPS; HTTPS only protects the connection, and the sender, Reply-To and link domain do not match campus.example. The logs show events from 198.51.100.23, including a successful password and an approved MFA prompt, but they do not prove who was using that address or how the password was obtained. MFA greatly reduces risk but can fail if a user approves an unexpected prompt. Preserve the logs, never delete them. Never send a password or OTP to anyone. The

student should change the password through the official portal, report to the college IT team, and review account activity. IT should revoke sessions and verify the facts before concluding.

D4 – AI-use declaration and evidence notes

AI-use declaration: see the AI-Use Declaration at the end of this report.

Evidence/reference notes:

1. **CISA – Secure Our World:** supports the basic practices used in Tasks A and B, namely unique strong passwords, using MFA, keeping software updated, and recognising and reporting phishing.
2. **NIST – Generative AI Profile, AI 600-1:** supports Task D's point that AI tools can produce confident but wrong statements (confabulation), so their output must be verified against evidence before it is trusted.

References

1. EWB Courses – AI-Powered Cybersecurity, Assessment 01: Security Foundations (issued 18 October 2026) – primary source for all scenarios and evidence.
2. CISA – Secure Our World (basic account and phishing guidance): https://www.cisa.gov/secure-our-world
3. NIST – Generative AI Profile, AI 600-1 (confabulation and verification): https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

AI-Use Declaration

I used an AI tool (Claude) for drafting, structuring and reviewing this assessment. All scenarios, logs and messages come only from the supplied EWB assessment PDF. I reviewed the answers against that evidence and the references above. No real passwords, OTPs or personal data were used, and no sample address was visited or tested.